

Part 1: Design of the Web-Based Voting System

Architectural Framework

The system uses a three-tier architecture:

- Client Layer: Voter web browsers.
- Application Layer: Servers in a Demilitarized Zone (DMZ), managing sessions and processing votes.
- Data Layer: A backend database within a protected network.

All communication uses HTTPS/TLS 1.3 for encrypted transport, preventing eavesdropping and man-in-the-middle attacks.

Core Components and Workflow

1. Voters access the system via a standard browser (e.g., Chrome or Safari). Authentication requires two-factor verification (2FA). After login, a time-limited session token is issued as a Secure, Http only cookie. This prevents theft via scripts or network sniffing. Tokens are rotated after login and invalidated on logout to block session hijacking.
2. Ballot Submission: All Votes are encrypted client-side and submitted via HTTPS POST requests to avoid exposing data in URLs. The server validates the session token and the voter's eligibility.
3. Database Interaction: The application uses prepared statements with bind variables for all database queries. This separates code from data, effectively neutralizing SQL injection attacks.
4. Postal Tallying: After polls close, encrypted votes are transferred to an air-gapped system for offline decryption and counting, preserving integrity and secrecy.

Security Infrastructure

- Network Defenses:
 - Stateful firewalls enforce access control lists (ACLs), allowing only essential traffic (e.g., HTTPS) and blocking unsolicited inbound connections to the internal database (
- Application Defenses:
 - All user input is validated and sanitised. Output is encoded to prevent Cross-Site Scripting (XSS), where malicious scripts are injected and executed in a victim's browser

PART 2: Identification and Description of Assets, Vulnerabilities, Threats, and Controls

Major Assets in the Voting System

1. **The Private Decryption Key:** This is the cryptographic key stored on the air-gapped tallying system and is used to decrypt votes after the polls close. It is one of the most valuable assets because whoever possesses this key can decrypt all cast votes, violating ballot secrecy and enabling vote manipulation. It is essential for the confidentiality and integrity of the vote data.
2. **Web Servers:** These serve as the central orchestration trust foundation. The servers host the entire voting application; if they crash, it would threaten fair elections. Their compromise represents a total breach of the system's operational trust, making them a critical asset.
3. **The Vote Database:** This holds exceptional importance because it represents the authoritative digital record of the election results. Any compromise of this database would directly threaten both the integrity and confidentiality of the election, making it the most vital data asset in the entire system.
4. **A Voter Session Token:** This is a short-lived digital key that confirms a voter's identity during an online voting session, which keeps the process smooth and secure by maintaining authentication without repeated logins. It is a crucial cybersecurity asset because anyone who steals it could impersonate the voter and cast a ballot in their place. It is important because protecting it directly protects the integrity of each individual vote.

THREATS AND HOW THEY WORK

Threat 1: Cross-Site Scripting (XSS) leading to session hijacking

Vulnerability: The website is taking user input and putting it back into the page without checking or cleaning it, which can let attackers inject code.

Attack: A hacker can then use this vulnerability to inject malicious code into the voting system that can act as the voter.

Technical Harm: By impersonating the voter the attacker can hijack the victim's active session, impersonating them to cast a fraudulent vote. This breaches authentication and the integrity of the individual's vote.

Attacker: a politically motivated group or external organization,

Security goals: Security Goals Breached: This attack compromises authentication, as the stolen session token allows the attacker to impersonate a legitimate voter. It also violates integrity, because the attacker can cast or alter a vote on the voter's behalf, undermining the accuracy of the election results.

Threat 2: Man-In-The-Middle Attack

Vulnerability: This vulnerability arises when voters use poorly protected public Wi-Fi networks such as libraries, allowing an attacker on the same network to place themselves between the voter's device and the internet connection, which exposes the voter's data to interception leading to a breach in privacy.

Attack: A hacker on the same unsecured network can interfere with the voter's connection to the online voting system, altering the voting session. By creating a fake Wi-Fi hotspot or exploiting weaknesses in a public network, the attacker can insert themselves into the network, allowing them to tamper with the voter's session and potentially modify a vote before it reaches the official server all without the voter's consent.

Technical Harm: Votes can be rigged or altered without the voter's knowledge, and personal information can be leaked.

Attacker: A third party with strong, opinionated views of one political party on public Wi-Fi networks.

Security Goals Breached: Authentication is compromised because intercepted credentials or session data could let an attacker impersonate a legitimate voter. Confidentiality is also broken, as private information — including a voter's identity or voting choices — can be exposed during transmission.

Threat 3: SQL Injection

Vulnerability: The vulnerability exists in the application's data layer. The system is not properly checking what people type into its forms, so harmful input can slip through and reach the database.

Attack: A hacker exploits the system's weak input handling by submitting harmful database commands, which can cause the system to expose private voter information or allow unauthorized changes to the election results.

Technical Harm: Votes can be modified or even deleted.

Security Goals Breached: This attack undermines Integrity because it allows unauthorized changes to the stored votes. It violates Confidentiality by exposing sensitive data, such as individual voter choices. It can also affect Availability if critical voting data is removed or disrupted, making parts of the system unusable.

Threat 4: Distributed Denial-of-Service (DDoS) Attack

Vulnerability: An overwhelming of the voting platform with so many requests that the voting system becomes slow or unavailable, which means votes cannot be accessed.

Attack: An attacker overwhelms the voting servers by sending a large number of fake connection attempts using false source addresses. Each attempt makes the server set aside resources for a connection that will never be completed, gradually exhausting its capacity and preventing real voters from accessing the system.

Technical Harm: Due to the overcrowding, the server loses capacity to handle new connections, leaving genuine users without a platform to vote. As a result, the voting platform shuts down, preventing people from submitting ballots.

Attacker: A rival group aiming to interfere with the election by manipulating results, exposing voter information, or disrupting the overall voting process.

Security Goals Breached: Integrity and Confidentiality. Integrity is breached by enabling unauthorized changes to stored votes. It violates confidentiality because private voter information or ballot choices can be exposed.

How To Stop These Threats

Control for threat 1: Cross-site Scripting (XSS)

Preventive control: Apply strict input validation and context-aware output encoding, supported by a strong Content Security Policy (CSP) to protect the online voting platform.

How it works the system checks and cleans any voter-supplied text so that harmful or unexpected characters cannot be processed as executable code.. Output encoding ensures that any voter-supplied information is displayed safely in the web browser as text rather than being interpreted as executable code. The CSP adds an additional safeguard by limiting which scripts are allowed to load or run, reducing the impact of any attempted overcrowding.

Minimizes harm by: preventing attackers from inserting or executing malicious scripts that could take over a voter's active session without consent . This protects voter authentication, stops session hijacking, and preserves the integrity of each individual ballot within the online voting

Control for threat 2 : Man- in- the -middle attack

Preventive control: implement HTTPS with HTTP Strict Transport Security (HSTS) across the entire online voting platform.

How it works: this helps to encrypts all data exchanged between the voter's device and the voting server, ensuring that information intercepted on an unsecured public Wi-Fi network remains unreadable to hackers therefore protecting the privacy of the votes. HSTS instructs browsers to connect *only* through secure HTTPS channels.

Minimizes harm by: providing strong end-to-end encryption that prevents attackers on public networks from viewing, altering, or injecting data into a voter's session. This protects voter credentials, prevents impersonation, and ensures that cast votes cannot be modified in transit, preserving both authentication and the integrity of the election process.

Control for threat 3: SQL Injection

Preventive control: introduce a security control like a Web Application Firewall (WAF)

How it works: Properly prepared queries ensure that any information entered by voters, such as login details or National Identification Number—is processed strictly as data rather than executable code making it difficult for hackers to interfere. Input checking ensures correctly formatted values are accepted by the voting system. The WAF blocks recognized SQL attack patterns before they can interact with the voting application.

Minimizes harm by: restricting voting databases and preventing harmful changes. This safeguards the accuracy of stored

Control for Threat 3: Denial-of-Service (DoS) via SYN Flood

Preventive & Detective control: Implement network-level DDoS protection mechanisms, including traffic scrubbing and SYN Cookies.

How it works: Upstream DDoS mitigation services filter malicious traffic (e.g., spoofed SYN packets) before it reaches the voting servers. Concurrently, SYN Cookies are enabled on the servers, eliminating the resource-exhaustion vulnerability by encoding connection state instead of allocating memory.

Minimises harm by: preserving service Availability. This ensures the voting platform remains accessible to legitimate voters during an attack, upholding the democratic process and preventing voter disenfranchisement.

Conclusion

This analysis confirms that securing an online voting system requires a defense-in-depth strategy. The identified threats target critical assets to breach core security goals. The proposed controls are essential to protect the election's integrity, confidentiality, and availability.